Day 29 Final Mini-Project: Incident Investigation Report

ID 810 — Hands-on Keyboard Attack Launched from a Compromised Account (Attack Disruption)

Oct 12, 2026 · Daniel Thibodeaux

Findings

A credential-theft tool (Mimikatz) was downloaded and executed on host MDF-DT-W11 under the context of account UserA, followed by execution of a MITRE ATT&CK-mapped discovery technique via Atomic Red Team. Microsoft Defender for Endpoint detected the activity through both static antivirus signatures and behavioral/EDR analysis, and Microsoft Defender's Attack Disruption capability automatically contained the account and isolated the device in response.

- **Time window:** 2026-10-12, 18:06 – 18:35 UTC
- **Host:** MDF-DT-W11 (192.168.139.151)
- **Account:** UserA: AzureAD, usera@30daychallenge1870.onmicrosoft.com
- **Incident ID:** 810 "Hands-on keyboard attack was launched from a compromised account"
- **Severity:** High
- **Tags:** Lateral Movement, Attack Disruption
- **Malware family:** Mimikatz
- **MITRE ATT&CK techniques:** T1059.001 (PowerShell), T1059.005 (Visual Basic), T1059.007 (JavaScript); discovery activity consistent with T1082 (System Information Discovery)
- **IOC — file names:** mimikatz.zip, mimikatz.exe, mimidrv.sys, mimilib.dll, mimispool.dll, T1059.001.yaml
- **IOC — URL:** raw.githubusercontent.com/S3cur3Th1sSh1t/... (Atomic Red Team test content, pulled by the T1082 technique's sub-tests)
- **Verdict:** True positive. This was a controlled lab exercise. The account owner intentionally downloaded and ran Mimikatz, then executed Atomic Red Team technique T1082, to observe Defender's detection and response behavior. No actual compromise occurred.
- **Response actions taken:** Attack Disruption automatically issued two separate actions. Contain user (UserA, 18:16 UTC) and Isolate device (MDF-DT-W11, 18:22 UTC). Both were manually released by the analyst after evidence collection.

Investigation Summary

On 2026-10-12 at approximately 18:06 UTC, the account UserA on host MDF-DT-W11 downloaded a copy of Mimikatz (mimikatz_trunk.zip) from its public GitHub release page. Microsoft Defender Antivirus detected the archive statically as malicious and prevented it from completing extraction, consistent with Mimikatz's well-known signature footprint. To continue the exercise, the analyst added a temporary Defender exclusion for the user's Temp directory, which allowed the archive to be extracted.

Evidence shows the Mimikatz binary and its supporting files (mimikatz.exe, mimidrv.sys, mimilib.dll, mimispool.dll) were written to disk at 18:11 UTC and flagged Malicious by Defender's antivirus engine, though the exclusion prevented an automatic quarantine action on these specific files. At 18:14 UTC, mimikatz.exe (PID 6704) was observed executing. This runtime execution was caught by Defender for Endpoint's behavioral/EDR engine, which does not rely on static file scanning and was unaffected by the Temp folder exclusion. Alert detail confirms the detection source as EDR, the detection technology as behavioral, and the category as SuspiciousActivity.

Two minutes later, at 18:16 UTC, Microsoft's Attack Disruption capability automatically issued a Contain user action against UserA, restricting the account's ability to authenticate and move laterally. The analyst then proceeded to run Atomic Red Team technique T1082 (System Information Discovery) to continue the planned exercise. At 18:18 UTC, Defender quarantined the technique's own test definition file (T1059.001.yaml) from an earlier, separate attempt to run technique T1059.001. PowerShell's test content was itself flagged as malicious and prevented, which forced the analyst to switch to T1082 instead. From 18:20 UTC onward, T1082's sub-tests executed successfully, generating a series of PowerShell processes and outbound requests to the Atomic Red Team test-content repository (raw.githubusercontent.com/S3cur3Th1sSh1t), each flagged Suspicious by EDR as expected for discovery-style command execution.

At 18:22 UTC, Attack Disruption escalated its response and issued an Isolate device action against MDF-DT-W11, cutting off the host's network access except for its connection to Defender's cloud service. This fully disconnected the VM from the internet and from the host's local network, which the analyst confirmed through failed `Test-NetConnection` attempts before identifying the isolation as the cause via Device Inventory and Action Center history.

Both of today's Attack Disruption actions: Contain user (UserA) and Isolate device (MDF-DT-W11), were manually reviewed and released by the analyst after evidence was collected. Based on the evidence available, this incident reflects correct detection and correct automated response: static AV caught the file-based threat, behavioral EDR caught the runtime execution that AV could not, and Attack Disruption correctly contained the compromised identity and endpoint without analyst intervention.

Who, What, When, Where, Why, How

- **Who:** Account UserA on host MDF-DT-W11. No other accounts or hosts were impacted; Incident 810's Assets tab confirms scope of exactly one device and one user.
- **What:** Mimikatz, a credential-theft tool, was downloaded, had an AV exclusion applied to bypass static detection, and was executed. This was followed by execution of Atomic Red Team technique T1082. Defender detected both the file and the runtime behavior, and Attack Disruption automatically contained the account and isolated the device.
- **When:** 2026-10-12, 18:06 – 18:35 UTC. The activity is not ongoing; both response actions were manually released by the analyst following evidence review.
- **Where:** Host MDF-DT-W11 (192.168.139.151), an on-premises lab VM, under account UserA (AzureAD-joined, Marketing Manager, Sales department).
- **Why:** This was an intentional, controlled exercise to observe how Microsoft Defender for Endpoint and Attack Disruption detect and respond to a credential-theft tool and a MITRE-mapped discovery technique. In a real-world equivalent, this exact behavior pattern is evidence of post-compromise credential access and reconnaissance.
- **How:** The analyst downloaded Mimikatz directly via PowerShell from its public GitHub release. Static detection initially blocked it; a manual Defender exclusion was required to allow it to run. Execution was still caught by behavioral/EDR detection, independent of the exclusion. Atomic Red Team's T1082 technique was then run via its PowerShell module to generate additional discovery-technique telemetry.

Recommendations

1. **Treat AV exclusions as an exception.** The Temp-folder exclusion used to bypass static detection for this exercise should be removed immediately after use and never left in place on a production or persistent endpoint, since it defeats static AV protection for that entire path going forward.
2. **Periodically audit the Action Center.** Contain user and Isolate device are independent actions that can fire separately from the same Attack Disruption event and must each be reviewed and released individually. Releasing one does not release the other. A routine check of Action Center history helps catch any action that was missed.
3. **Confirm behavioral/EDR detection coverage is active before relying on static AV exclusions for testing.** In this case, EDR detection caught what static AV exclusion missed, which is the desired defense-in-depth outcome, but this should not be assumed without verification in every environment.

Secondary Finding: Phishing Simulation and Risky Sign-In (richard.hale)

Separately from Incident 810, two unrelated simulated scenarios were executed on 2026-10-12 against account richard.hale. These do not share any host, account, or technique overlap with the Mimikatz/Atomic Red Team activity above and are documented here as a distinct, shorter finding.

Phishing simulation: A lure email “Invoice is ready for viewing” was sent from a newly created external sender mdfdt.sender.sim@outlook.com to richard.hale@30daychallenge1870.onmicrosoft.com. The display text “View Invoice” linked to an unrelated external domain (docusign.com), a classic link-mismatch lure pattern. The first send attempt, at approximately 16:37 UTC, was blocked by Microsoft’s own sender-abuse detection on the new account; a second attempt, after account verification, succeeded at 17:08 UTC and was correctly quarantined by Exchange Online Protection as High Confidence Phish. The message was released for demonstration purposes and confirmed to carry a Safe Links rewrite on delivery, preserving the real destination URL for inspection.

Risky sign-in: richard.hale successfully signed in to Outlook on the web from a VPN exit node in Bucuresti, Romania (187.13.27.139) at 17:21 UTC. Conditional Access evaluated the sign-in correctly and did not block it, since Romania is not among the blocked countries configured in the tenant’s existing Conditional Access policy (which targets Japan only). No MFA challenge occurred, consistent with the tenant’s security defaults being disabled. A check of Identity Protection’s Risky sign-ins and Risk detections for this event returned no results, likely because the account lacks sufficient sign-in history for the risk engine to flag the location as atypical.

Recommendation: If geographic risk detection is a goal for future exercises, establish a baseline sign-in history for test accounts first, since Identity Protection’s risk-based detections depend on deviation from an established pattern rather than absolute geography alone.

Supporting Evidence

Incident 810 — Mimikatz / Atomic Red Team

Figure 1: Defender Antivirus static detection blocking mimikatz.zip extraction and Windows Security “Threats found” notification at time of static detection

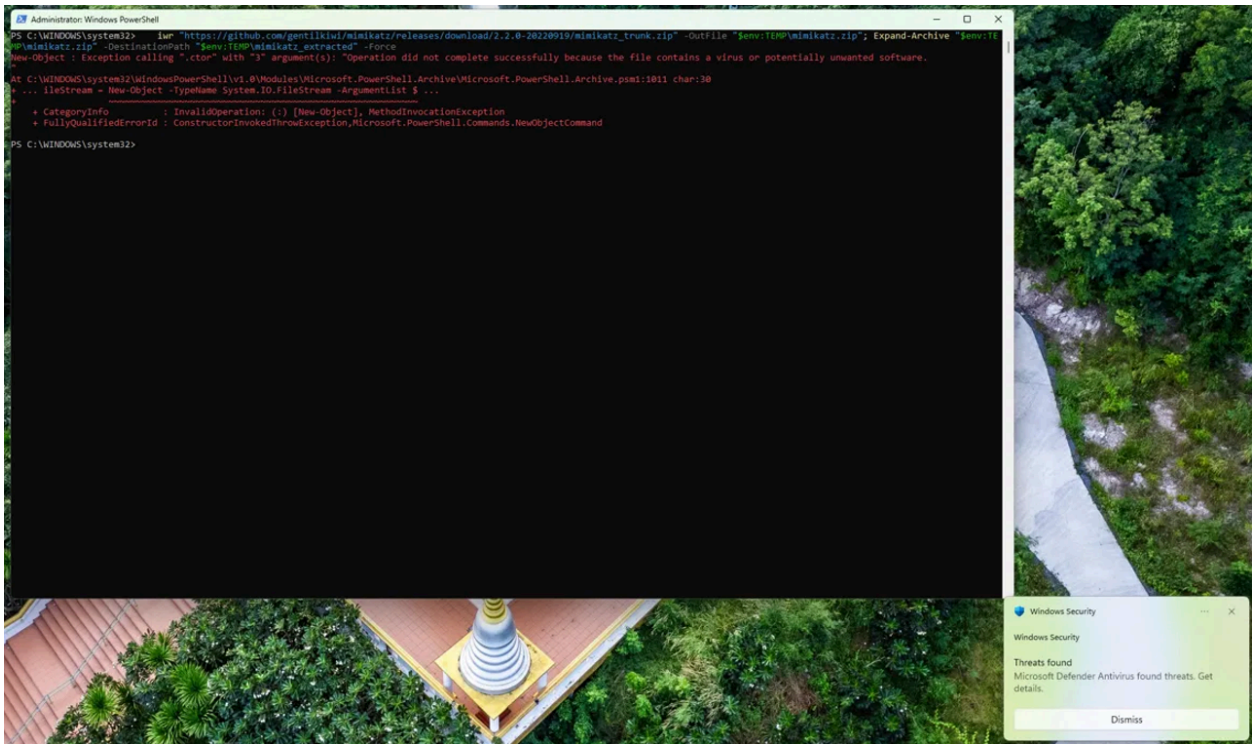


Figure 2: Action Center detail panel for the Isolate device action. Detection Source: EDR, Detection technology: Behavioral, Category: SuspiciousActivity, linked to Incident 810

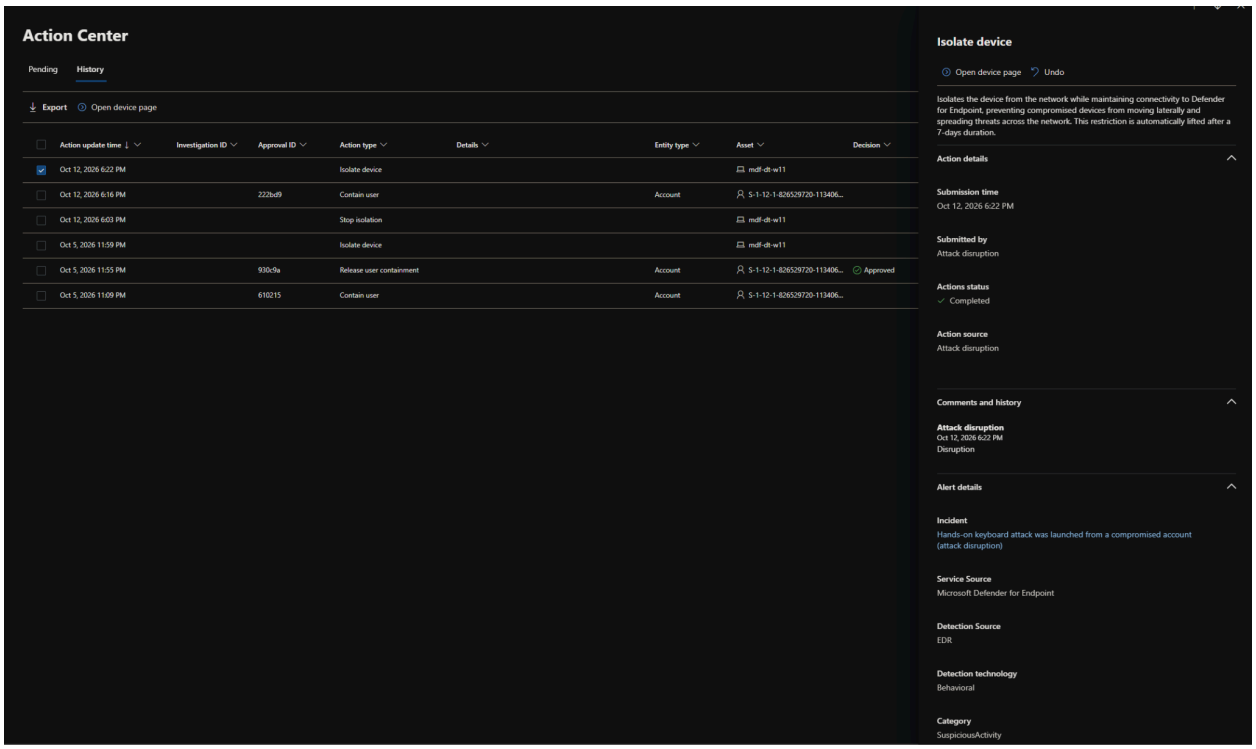


Figure 3: Action Center history table. Contain user 18:16 UTC and Isolate device 18:22 UTC, both sourced from Attack disruption

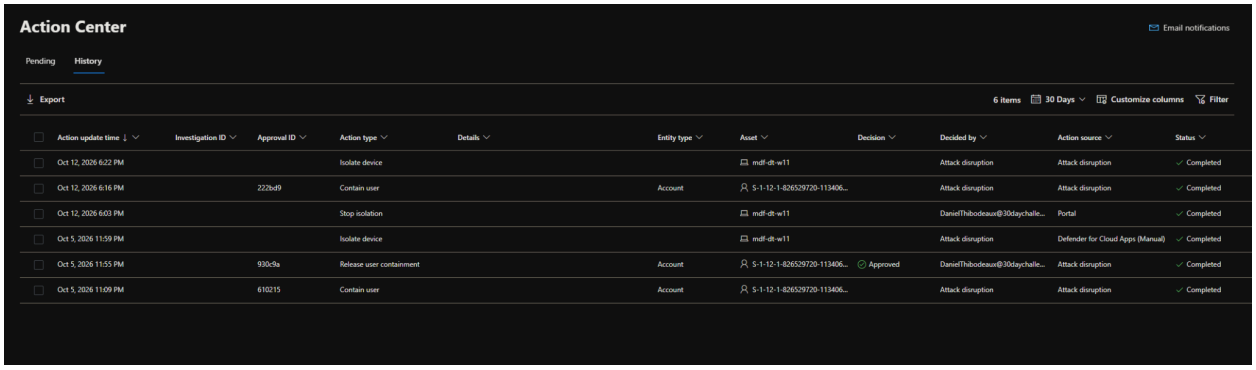


Figure 4: Incident 810 Attack story graph. Priority assessment is 100, MITRE techniques (T1059.001, T1059.005, T1059.007), incident graph showing MDF-DT-W11, 2 Users (1/2 Contained), 6 URLs, 2 Registry values, 5 Processes, 15 Files

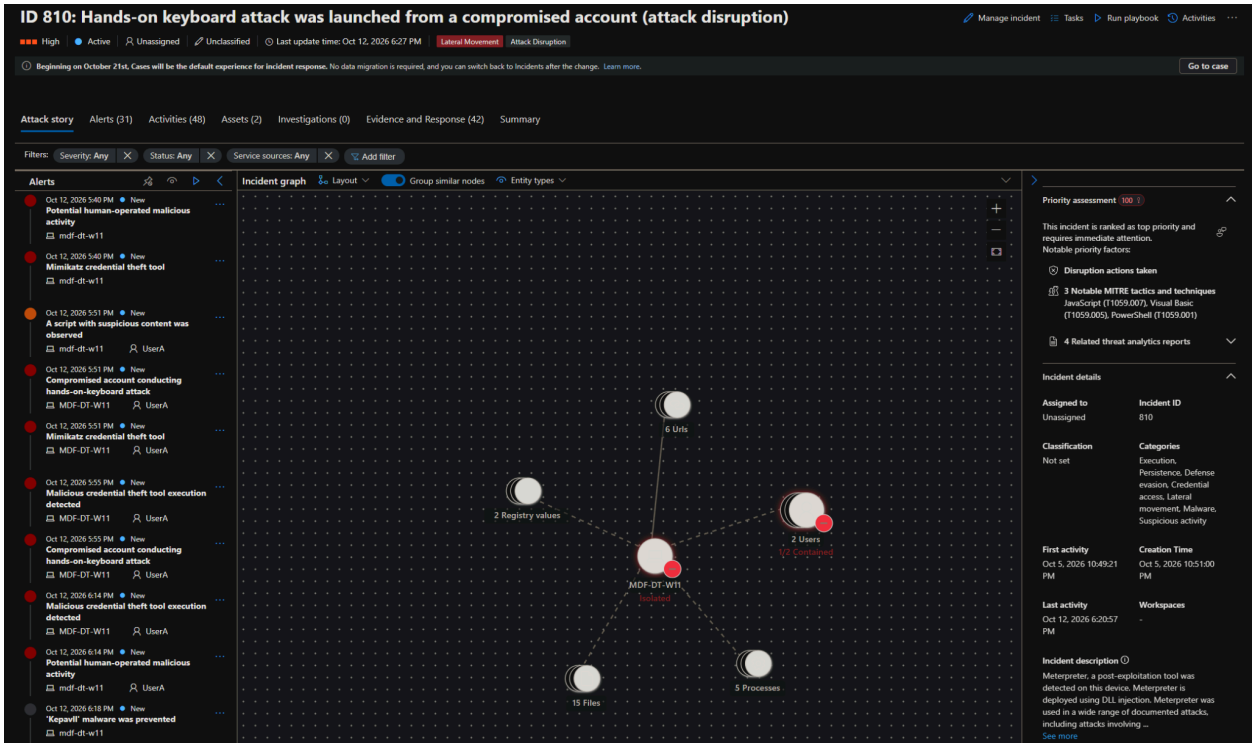


Figure 5: Incident 810 Evidence and Response tab — 42 items, showing mimikatz.zip/exe/dll/sys entries (Malicious) and T1059.001.yaml (Malicious, Prevented) with timestamps

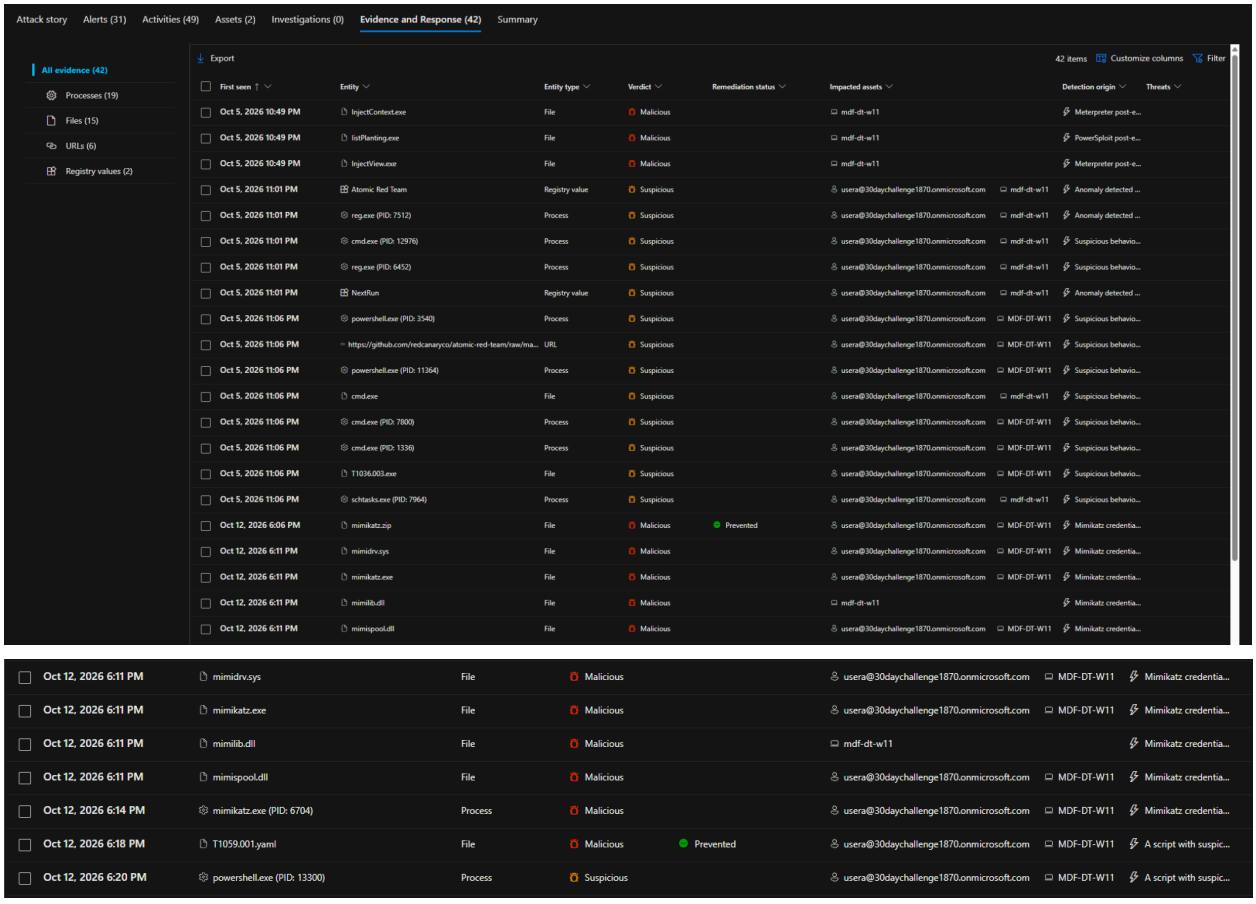


Figure 6: Atomic Red Team T1082 terminal output showing successful sub-test execution on MDF-DT-W11

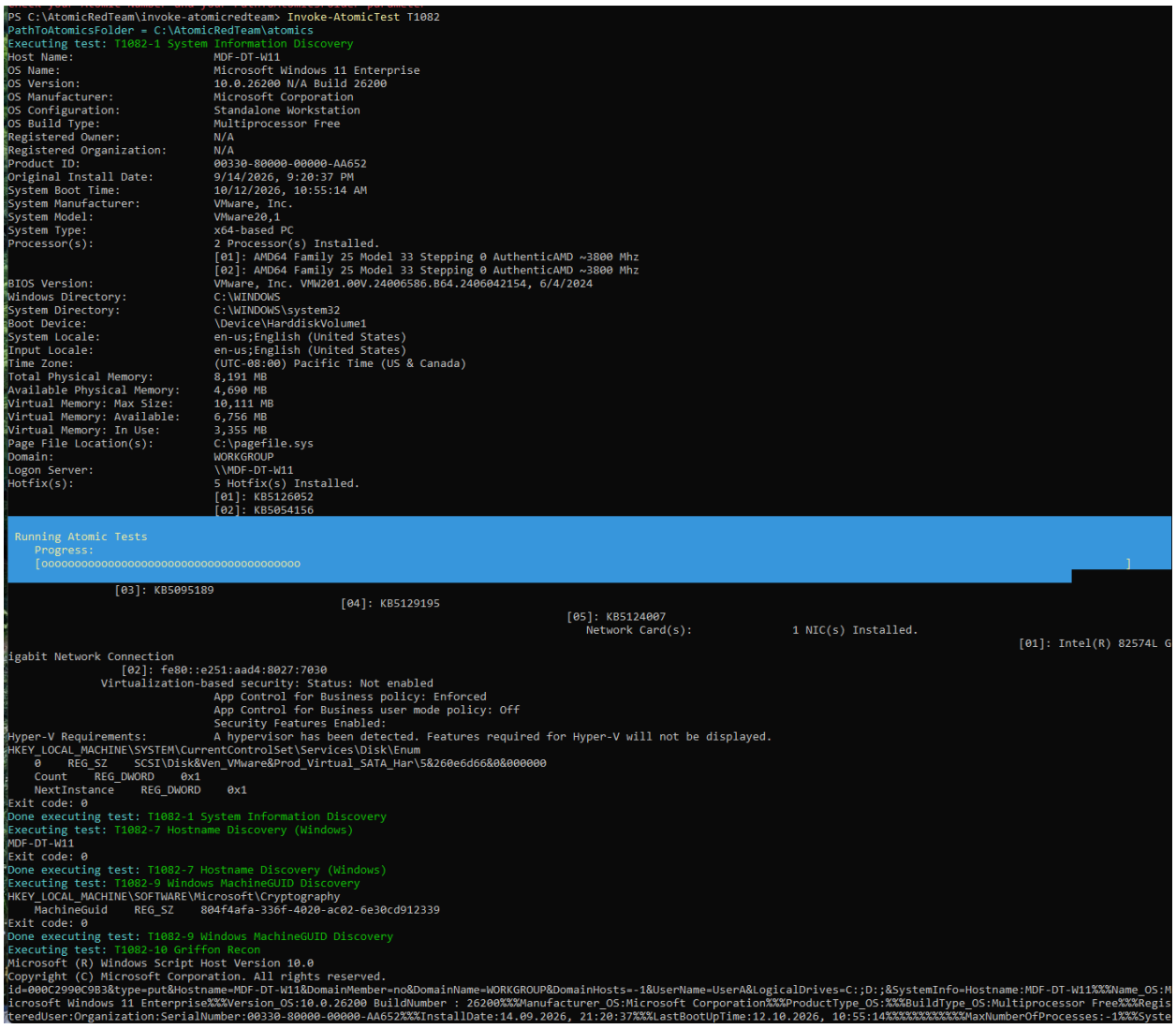
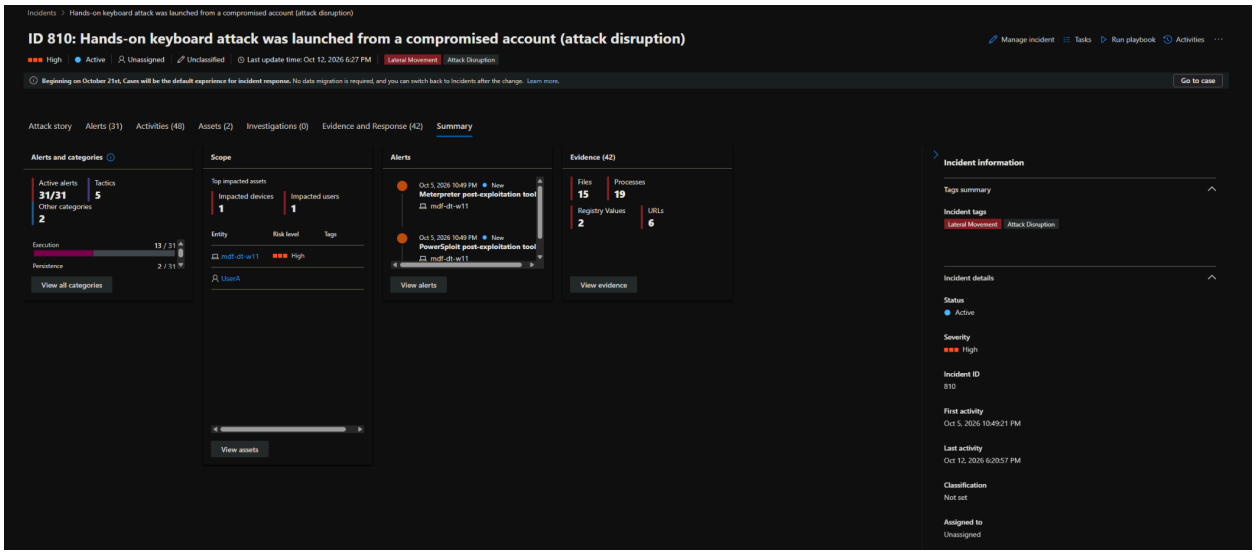


Figure 7: Incident 810 Summary tab: Active alerts 31/31, Impacted devices 1, Impacted users 1



Secondary finding — Phishing / Risky sign-in

Figure 8: Quarantine entry for “Invoice is ready for viewing_01”. Sender mdfdt.sender.sim@outlook.com, High Confidence Phish

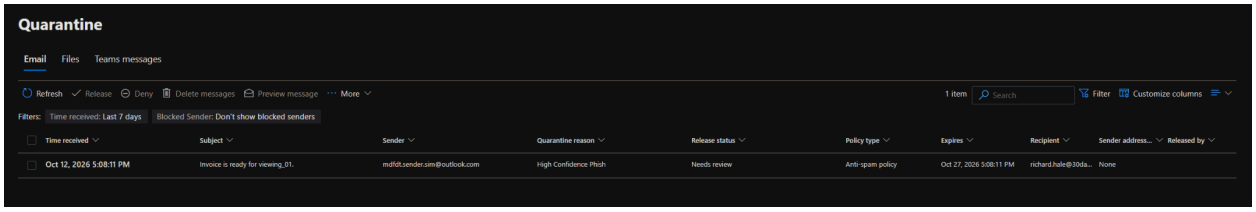


Figure 9: Delivered message with Safe Links rewrite visible on link hover

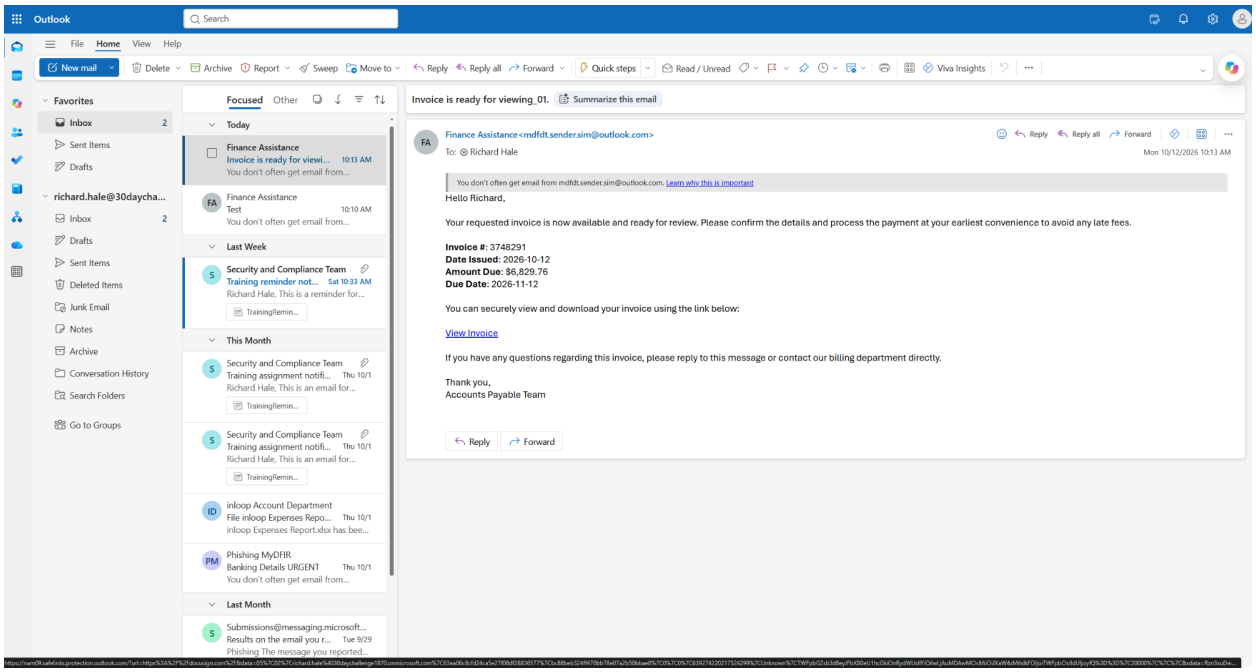


Figure 10: VPN IP geolocation (Bucuresti, Romania, 187.13.27.139)

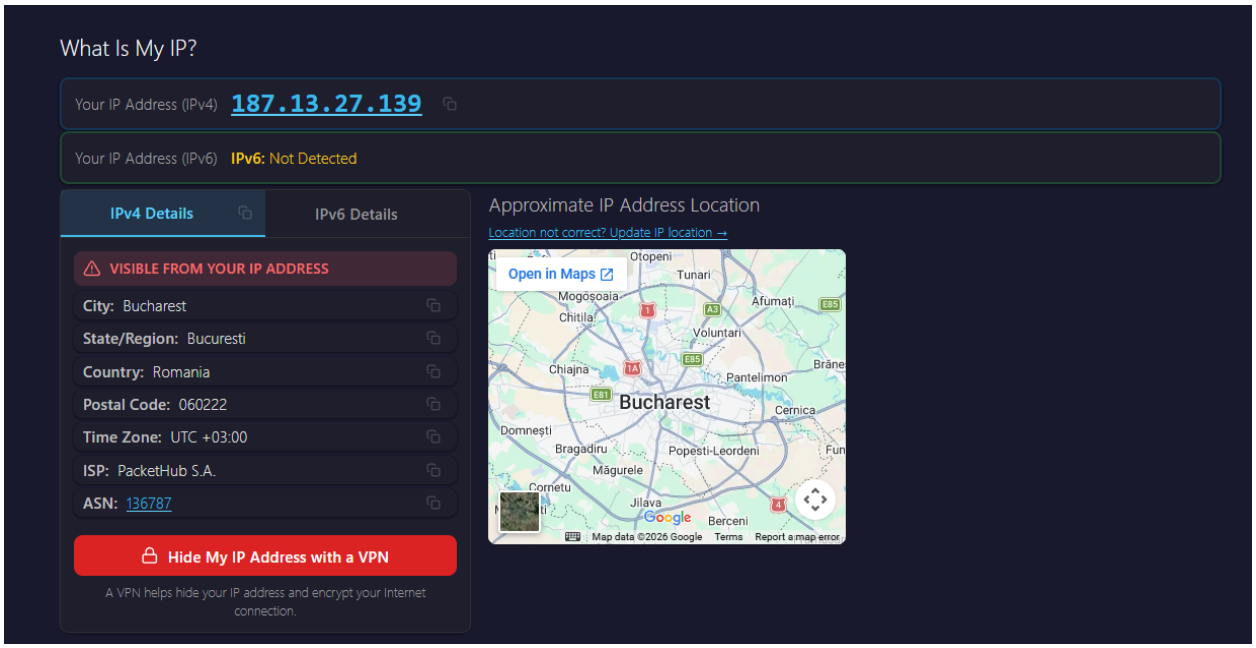


Figure 11: Entra ID sign-in log — richard.hale, Romania, Status: Success, Conditional Access: Success

